

Network Security: Advanced Patterns

Beyond NSGs — Azure Firewall, DDoS Protection, WAF, and Network Watcher for defense-in-depth

 Advanced

 20 Minutes

 AZ-104 · Module 04

Why This Matters

NSGs and routing control which traffic is allowed, but they work at Layer 3 (network). Modern attacks happen at Layer 7 (application) — SQL injection, DDoS, bot attacks. This doc covers the advanced tools that protect above NSGs: Azure Firewall (stateful inspection), DDoS Protection (volumetric attacks), Web Application Firewall (app-level threats), and Network Watcher (diagnostics).

Before You Start

Prerequisites	VNets & Subnets, Network Security Groups, Routing Fundamentals, Hub-Spoke Topology
Time to understand	20 minutes
Difficulty	 Advanced (builds on all networking concepts)
What you'll learn	Stateful firewalls, application-level protection, DDoS mitigation, network diagnostics

The Simple Idea: Layers of Network Security

Earlier docs covered Layers 2-3 (NSGs, routing). This doc covers Layers 4-7 (advanced security).

- **Layer 7 (Application):** WAF blocks SQL injection, XSS
- **Layer 4 (Transport):** DDoS Protection blocks volumetric attacks

- **Layer 3 (Network):** Azure Firewall allows/denies by IP/port/protocol
- **Layer 2 (Data Link):** NSGs filter by subnet/NIC

```
Layer 7 (Application)    ← WAF blocks SQL injection, XSS
    ↓
Layer 4 (Transport)      ← DDoS Protection blocks volumetric attacks
    ↓
Layer 3 (Network)        ← Azure Firewall allows/denies by IP/port/protocol
    ↓
Layer 2 (Data Link)      ← NSGs filter by subnet/NIC
```

When NSGs Aren't Enough

NSG Example

```
Rule: Allow port 443 from 0.0.0.0/0
├ Result: Any traffic on port 443 is allowed
├ Includes: Legitimate HTTPS traffic ✓
├ Includes: DDoS attack on port 443 ✗
├ Includes: SQL injection via HTTPS ✗
└ NSG can't see inside the traffic, only the port
```

Advanced Security Needed

```
Azure Firewall:
├ Can see the application data
├ Can block SQL injection patterns ✓
├ Can block malicious URLs ✓
└ But adds latency (inspection takes time)

DDoS Protection:
├ Detects flood attacks (millions of requests/sec)
├ Automatically rate-limits offenders ✓
└ Protects infrastructure from being overwhelmed

WAF (Web Application Firewall):
├ Sits in front of web apps
```

- └ Blocks OWASP Top 10 attacks (XSS, SQLi, etc.)
- └ Can identify legitimate traffic vs. malicious
- └ Works with Application Gateway or Front Door

Layer 4: DDoS Protection

What Is a DDoS Attack?

DDoS (Distributed Denial of Service) = Overwhelming a service with traffic so legitimate users can't reach it.

Real-World Analogy: Crowded Restaurant

Normal traffic: a customer goes through the waiter to the kitchen and gets food. A DDoS attack is like 1000 fake customers overwhelming the waiter so real customers can't be served. Protection is a bouncer at the door who questions suspicious groups, blocks obvious fakes, and lets real customers through.

Normal Traffic:

Customer → Waiter → Kitchen → Food ✓

DDoS Attack:

1000 fake customers → Waiter → Can't serve real customers ✗

Protection:

- └ Bouncer at door: "These 1000 people look fake"
- └ Asks questions: "Where are you from? Why here?"
- └ Blocks obvious fakes ✓
- └ Real customers still get served ✓

Azure DDoS Protection Tiers

Tier	Cost	Detection	Mitigation	Best For
------	------	-----------	------------	----------

Basic	Free	Azure automated	Automatic	All subscriptions (always on)
Standard	~\$3K/month	24/7 monitoring	Automatic + manual	Mission-critical apps

DDoS Basic vs. DDoS Standard

DDoS Basic (Always On, Free)

Included with every Azure subscription:

- └ Always monitoring incoming traffic
- └ Auto-blocks obvious DDoS attacks (SYN floods, UDP floods)
- └ No configuration needed
- └ Works at network edge (before traffic reaches your VNet)

Limitations:

- └ Doesn't monitor application-level attacks
- └ Limited visibility (you don't see metrics)
- └ No custom policies

DDoS Standard (Paid, Enterprise-Grade)

Enable on public IP or VNet:

- └ 24/7 dedicated support team
- └ Real-time attack analytics
- └ Custom mitigation policies
- └ Attack simulation (test your defenses)
- └ Cost: ~\$3000/month (expensive but justified for critical apps)

Example Policy:

- └ If traffic exceeds 100 Gbps → Rate-limit to 50 Gbps
- └ If SYN flood detected → Block source IPs
- └ If UDP flood detected → Drop UDP packets
- └ Legitimate traffic passes through ✓

When to Use DDoS Standard

Use DDoS Standard if:

- └ App is internet-facing (has public IP)
- └ App is mission-critical (downtime = lost revenue)
- └ Traffic patterns are predictable (can set thresholds)
- └ Example: E-commerce site, financial API, public website

Don't use if:

- └ Internal-only app (not exposed to internet)
- └ Testing/development environment
- └ Traffic highly variable
- └ Example: Dev VMs, internal apps, test systems

Layer 3: Azure Firewall (Stateful Inspection)

Stateless vs. Stateful Firewalls

NSG (Stateless)

Rule: Allow port 443

- └ Sees: Source IP, Dest IP, Port, Protocol
- └ Decision: Port 443? YES → Allow
- └ Doesn't understand: Is this a legitimate HTTPS connection?
- └ Can't see: Application data, conversation context

Azure Firewall (Stateful)

Connection: Client → Server on port 443

- └ Sees: TLS handshake, certificate, domain
- └ Understands: "This is HTTPS to example.com"
- └ Knows: "Example.com is on the allowed list"
- └ Allows: Traffic ✓
- └ Understands: "This is a complete HTTPS connection"
- └ Can inspect: Application layer (if configured)

Azure Firewall Capabilities

Network Rules (Layer 4):

- └ Allow/deny by IP, Port, Protocol
- └ Similar to NSG, but stateful
- └ Example: Allow 10.0.0.0/16 to reach 192.168.0.0/16 on port 443 ✓

Application Rules (Layer 7):

- └ Allow/deny by domain name (not just IP)
- └ Understands FQDN (fully qualified domain name)
- └ Example: Allow outbound to *.microsoft.com (any Microsoft domain)
- └ Example: Block *.twitter.com (block all Twitter domains)
- └ Much more flexible than IP-based filtering ✓

NAT Rules (Network Address Translation):

- └ Redirect inbound traffic
- └ Example: Public IP:443 → Internal VM:8443

- └─ Allows internal VMs to receive internet traffic
- └─ Hides internal IPs from internet

Azure Firewall Architecture

Azure Firewall lives in the Hub VNet's **AzureFirewallSubnet** with its own public IP. The hub routes all internet and on-prem traffic through the firewall, and spoke VNets route their outbound traffic to the hub firewall too — eliminating the need for a firewall per spoke.

```
Hub VNet (with Firewall)
└─ AzureFirewallSubnet (10.0.2.0/24)
  └─ Azure Firewall instance
  └─ Assigned public IP
  └─
└─ Routes to Firewall:
  └─ 0.0.0.0/0 (internet) → Firewall
  └─ 192.168.0.0/16 (on-prem) → Firewall
  └─
└─ All internet/on-prem traffic passes through firewall ✓

Spoke VNet:
└─ Route: 0.0.0.0/0 → Hub Firewall (10.0.2.4)
└─ Route: 192.168.0.0/16 → Hub Firewall
└─ Outbound traffic: Automatically inspected ✓
└─ No need for firewall per spoke (cost-effective) ✓
```

Firewall Rule Evaluation Order

```
Traffic arrives at Firewall:
↓
Check NAT Rules (highest priority)
└─ If match → Translate and continue
↓
Check Network Rules
└─ If match (allow) → Forward ✓
└─ If match (deny) → Drop X
```

```
↓  
Check Application Rules  
└─ If match (allow) → Forward ✓  
└─ If match (deny) → Drop X  
↓  
Default: Deny (implicit deny)
```

Layer 7: Web Application Firewall (WAF)

What Is a WAF?

WAF = Protects web applications from Layer 7 attacks (not network attacks, but web app attacks).

Attacks WAF Protects Against

SQL Injection

```
Attacker sends: ' OR '1'='1  
WAF detects: SQL injection pattern  
WAF blocks: Request ✓
```

Cross-Site Scripting (XSS)

```
Attacker sends: <script>alert('hacked')</script>  
WAF detects: JavaScript in form field  
WAF blocks: Request ✓
```

Cross-Site Request Forgery (CSRF)

```
Attacker sends: Malicious form from external site  
WAF detects: Request from unexpected origin  
WAF blocks: Request ✓
```

Path Traversal


```
Attacker sends: ../../../../etc/passwd
WAF detects: Directory traversal pattern
WAF blocks: Request ✓
```

WAF Deployment Models

Azure WAF can attach to:

Service	How	Cost
Application Gateway	Sits in front of web servers	Charged for gateway + WAF rules
Azure Front Door	Global load balancer + WAF	Higher cost, global coverage
CDN (Content Delivery)	Via Azure CDN + WAF rules	Cheaper, good for static content

WAF Rule Sets (OWASP)

Azure WAF comes with default rule sets covering standard protection (OWASP 3.0: SQL Injection, XSS, Remote Code Execution rules, etc.), plus custom rules you create yourself — such as blocking IPs by geography or behavior pattern, requiring specific headers, or rate-limiting by source IP.

```
Azure WAF comes with default rule sets:
├─ OWASP 3.0 (standard protection)
│   ├── SQL Injection rules
│   ├── XSS rules
│   ├── Remote Code Execution rules
│   └─ etc.
└─ Custom Rules (create your own)
    ├── Block IPs by geography
    └─ Block IPs by behavior pattern
```

- └ Require specific headers
- └ Rate-limit by source IP

WAF Example: E-Commerce Site

Architecture:

Internet → Azure Front Door (global) → WAF (block attacks)
→ Application Gateway → Web servers → SQL DB

Traffic Flow:

1. Attacker sends: `SELECT * FROM users; DROP TABLE users;`
2. Front Door receives (near attacker's region)
3. WAF rule: SQL Injection pattern detected
4. WAF blocks: Request rejected, attacker gets 403 Forbidden
5. Legitimate customer: Normal shopping request
6. WAF rule: No attack patterns
7. WAF allows: Request passes through to App Gateway
8. App Gateway: Load balances to web servers
9. Web servers: Process legitimate request
10. Result: Site protected from attacks ✓

Layer 2: Network Watcher (Diagnostics)

What Is Network Watcher?

Network Watcher = Diagnostic tools to monitor, diagnose, and visualize network issues.

Network Watcher Tools

IP Flow Verify

Question: "Can this VM reach that VM?"

Input: Source IP, Dest IP, Port, Protocol

Output: "YES (allowed by NSG)" or "NO (blocked by NSG)"

Use: Debug connectivity issues ✓

Example: Is the database reachable on port 1433?

Connection Troubleshoot

Question: "Why can't I reach that endpoint?"

Input: Source VM, Destination IP/host

Output: Detailed hops and where connection fails

Use: Diagnose routing and firewall issues ✓

Example: Find where connection breaks (routing loop? firewall?)

NSG Flow Logs

Records: All traffic allowed/denied by NSG

Captures: Source, Dest, Port, Protocol, Allow/Deny

Use: Compliance, security audits, understanding traffic ✓

Storage: Log Analytics, Storage Account, Event Hub

Example: "Which IPs are trying to attack my database?"

Packet Capture

Records: Actual packet data (headers and payload)

Use: Deep troubleshooting, malware analysis

Warning: Can capture sensitive data (passwords, keys)

Example: "What data is being sent on this connection?"

Connection Monitor

Monitors: Connectivity from VM to destination

Tracks: Latency, packet loss, hop information

Use: Continuous health monitoring ✓

Example: "Is my connection to the database stable?"

NSG Flow Logs Example

Flow Log Entry:

```
{  
  "time": "2024-06-14T10:30:45Z",
```

```
"systemId": "nic-abc123",
"category": "NetworkSecurityGroupFlowEvent",
"resourceId": "/subscriptions/.../subnets/web",
"operationName": "NetworkSecurityGroupFlowEvents",
"properties": {
  "Version": 2,
  "flows": [
    {
      "rule": "AllowHTTPSInternet",
      "flows": [
        {
          "mac": "00:0D:3A:12:34:56",
          "flowTuples": [
            "1623667845,40.88.45.120,10.0.1.5,443,52413,T,O,A,B,,",
            ↑           ↑           ↑           ↑   ↑   ↑ ↑ ↑
            time      src-IP      dst-IP      port  port  T O A
                      (internet) (vm)                C (TCP) (Out)(Allow)
          ]
        }
      ]
    }
  ]
}
```

Interpretation:

- └ 40.88.45.120 (Internet IP) sent traffic
- └ To 10.0.1.5 (Your VM) on port 443
- └ From port 52413 (ephemeral)
- └ Protocol: TCP
- └ Direction: Outbound (from your perspective)
- └ Action: Allowed
- └ Used by: NSG rule "AllowHTTPSInternet"

Worked Example: Real Scenario

The Scenario

E-Commerce Site (TechCorp):

- Public website: example.com (handles customer traffic)
- Backend databases: Sensitive customer data

- Global users: Need fast access from anywhere
- Under attack: Getting DDoS attacks (competitors?)

Security Architecture

Internet (users + attackers)

↓

Azure DDoS Standard (Layer 4)

- └ Rate-limits volumetric attacks
- └ Cost: ~\$3000/month but necessary for e-commerce

↓

Azure Front Door (global)

- └ Distributes traffic across regions
- └ Caches static content
- └ Reduces load on backend

↓

WAF Rules (Layer 7)

- └ OWASP rules: Block SQL injection, XSS, CSRF
- └ Custom rules: Block suspicious IPs, geo-blocking
- └ Action: Deny malicious requests

↓

Azure Firewall (Layer 3-4)

- └ Network rules: Allow only known sources
- └ Application rules: Allow only example.com domain traffic
- └ Action: Inspect and allow legitimate traffic

↓

Application Gateway (Layer 7)

- └ Web application firewall (additional layer)
- └ SSL/TLS termination
- └ Load balancing
- └ Action: Distribute to backend pools

↓

Backend Servers (VMs)

- └ NSG: Allow only from Application Gateway
- └ NSG: Block all unknown sources
- └ Protected by multiple layers ✓

Attack Scenarios

Scenario 1: Volumetric DDoS

Attack: 100 Gbps traffic from 50K compromised IoT devices

Protection Flow:

1. DDoS Standard detects: Traffic exceeds normal pattern
 2. DDoS Standard rate-limits: Drops excess packets
 3. Legitimate users: Still able to access ✓
 4. Attacker: Can't overwhelm the service
 5. Result: Service stays online ✓
- Cost: Justifies the \$3000/month DDoS Standard subscription

Scenario 2: SQL Injection

Attack: Attacker sends: GET /product?id=1' OR '1'='1--

Protection Flow:

1. Request hits Azure Front Door (Layer 4)
2. Front Door forwards to WAF
3. WAF checks: OWASP SQL Injection rule
4. WAF detects: SQL injection pattern
5. WAF blocks: 403 Forbidden
6. Attacker gets: Error page (not access to data)
7. Backend: Never sees the malicious request ✓
8. Result: Database protected ✓

Scenario 3: DDoS + Application Attack

Attack: 10 Gbps flood of requests from 1000 IPs
+ SQL injection payloads

Protection Layers:

- Layer 4 (DDoS): Rate-limits volumetric flood ✓
- Layer 7 (WAF): Blocks SQL injection payloads ✓
- Layer 3 (Azure Firewall): Network rules as fallback ✓
- Layer 2 (NSG): Final protection at subnet level ✓

Result:

- └─ DDoS attack: Mitigated by rate-limiting
- └─ SQL injection: Blocked by WAF
- └─ Legitimate traffic: Passes through all layers
- └─ Site remains available and secure ✓

Monitoring Attack Flow with Network Watcher

Use Network Watcher:

1. NSG Flow Logs enabled:
 - └─ Captures all traffic (allowed + denied)
 - └─ Shows which IPs are attacking
 - └─ Stored in Log Analytics for analysis
2. Query Attack Pattern:
 - └─ KQL: NSGFlowLogCommonFields
 - | where FlowStatus == "Deny"
 - | summarize DeniedCount = count() by SourcePublicIP
 - | sort by DeniedCount desc
3. Result:
 - └─ Top attacking IPs identified
 - └─ Patterns visible (which ports, protocols)
 - └─ Can create firewall rules to pre-block ✓
4. Connection Monitor:
 - └─ Monitors legitimate user access
 - └─ Tracks latency (is site fast enough?)
 - └─ Alerts on degradation
 - └─ Ensures customer experience ✓

Common Mistakes (What NOT to Do)

✗ Mistake 1: Thinking Firewall Replaces NSGs

Wrong

"We have Azure Firewall, we don't need NSGs"

- └ Remove NSG rules
- └ Rely only on Firewall
- └ Problem: NSGs are still needed at subnet level
- └ Result: Defense-in-depth is gone ✗

Fix

Use both:

- └ NSG: Blocks at subnet level (quick, lightweight)
- └ Firewall: Inspects at hub level (stateful, deep inspection)
- └ Result: Multiple layers of defense ✓

Why it fails: Firewall and NSGs serve different purposes (stateful inspection vs. subnet isolation).

✗ Mistake 2: Not Enabling NSG Flow Logs

Wrong

"NSG Flow Logs are expensive, let's skip them"

- └ No visibility into denied traffic
- └ Can't debug connectivity issues
- └ Can't investigate security incidents
- └ Result: Blind to attacks ✗

Fix

Enable NSG Flow Logs:

- └ Store in Log Analytics (cheap, queryable)
- └ Set retention to 90 days minimum
- └ Query for:
 - └ Denied traffic patterns
 - └ Unusual port access
 - └ Potential attacks
- └ Cost: ~\$10/month (cheap insurance) ✓

Why it fails: Flow logs are the audit trail for network security.

✗ Mistake 3: WAF Too Strict

Wrong

WAF Rule: Block all requests with special characters

- └ Legitimate request: "What's the price?"
- └ Contains apostrophe (special character)
- └ WAF blocks: Legitimate user can't search
- └ Result: False positives, broken site ✗

Fix

WAF Tuning:

- └ Start with default OWASP rules
- └ Monitor for false positives
- └ Exclude specific paths (e.g., file uploads)
- └ Adjust sensitivity: "Detection" vs. "Prevention" mode
- └ Result: Security without breaking functionality ✓

Why it fails: Over-blocking legitimate traffic hurts user experience.

✗ Mistake 4: DDoS Protection Only, Ignoring Application Attacks

Wrong

"We have DDoS Standard, we're protected"

- └ DDoS protects Layer 4 (volumetric)
- └ Doesn't protect Layer 7 (SQL injection, XSS)
- └ Attacker uses targeted SQL injection
- └ Database hacked
- └ Result: False sense of security ✗

Fix

Use layered defense:

- └ DDoS Standard: Handles volumetric attacks
- └ WAF: Handles application-level attacks
- └ Azure Firewall: Network-level inspection
- └ NSGs: Subnet-level filtering
- └ Result: Protected at all layers ✓

Why it fails: DDoS and WAF protect different layers.

Advanced Security Checklist

DDoS Protection

- DDoS Basic: Always enabled (free)
- DDoS Standard: Enable for public-facing apps
 - └ Cost-benefit: \$3000/month vs. downtime cost
- DDoS alerts: Configure to notify SOC

Azure Firewall

- Deployed in Hub VNet
- Application rules: Define allowed domains
- Network rules: Define allowed IPs/ports
- Routes: All spoke traffic through firewall
- Logging: Enable firewall logs
- Tuning: Monitor allowed vs. denied traffic

WAF (Application Gateway or Front Door)

- OWASP rules enabled
- Mode: Detection (first), then Prevention (after tuning)
- Custom rules: Add for your app-specific threats
- Exclusions: Configure for file uploads, legitimate patterns
- Logging: Send to Log Analytics for analysis

Network Watcher

- NSG Flow Logs: Enabled on all NSGs
- Storage: Log Analytics (for querying)
- Retention: 90 days minimum
- Alerts: Set for unusual patterns
- Connection Monitor: Monitor critical connections
- IP Flow Verify: Used for troubleshooting

Incident Response

- **Process:** What to do when NSG Flow Logs show attack
- **Ownership:** Who investigates security incidents?
- **Playbook:** Steps to block, isolate, remediate
- **Communication:** How to notify customers/stakeholders

How This Connects to Other Topics

Related to Module 01 (Identity & Governance)

- **RBAC:** Only network admins can modify firewall rules
- **Policy:** Enforce firewall + WAF for all public-facing apps

Related to Module 02 (Storage)

- **Storage Firewall:** Combined with WAF for secure access

Related to Module 05 (Monitor)

- **Log Analytics:** Analyze NSG Flow Logs and Firewall logs
- **Alerts:** Trigger on suspicious patterns

See It In Action

Associated labs:

- **Lab 15: Azure Firewall** (if exists)
- **Lab 19: Network Watcher & Diagnostics** (if exists)

Suggested learning sequence:

1.  Read **Hub-Spoke Topology**
2.  Read this doc (Network Security Advanced)
3.  Hands-on: Set up Azure Firewall in hub
4.  Hands-on: Enable NSG Flow Logs

5. Hands-on: Deploy WAF on Application Gateway

Key Takeaways

Summary

- **Defense-in-depth:** Use multiple security layers (DDoS, Firewall, WAF, NSG)
- **DDoS Standard:** Essential for internet-facing critical apps (~\$3K/month)
- **Azure Firewall:** Stateful inspection, application rules, centralized policy
- **WAF:** Protects against Layer 7 attacks (SQL injection, XSS, CSRF)
- **NSG Flow Logs:** Visibility into allowed/denied traffic (essential for auditing)
- **Network Watcher:** Diagnostic tools for troubleshooting and monitoring
- **Layered approach:** Each layer catches different attack types
- **Tuning required:** Monitor for false positives, adjust rules as needed

Next Steps

1. **Learn:** Read this doc (you're here)
2. **Understand:** Which advanced security tools apply to your workloads
3. **Implement:** Deploy in order: DDoS → Firewall → WAF
4. **Monitor:** Enable NSG Flow Logs and set up alerts
5. **Practice:** Use Network Watcher to diagnose connectivity
6. **Secure:** Test security with network watcher and flow logs

© 2026 — AZ-104 Learning Hub. For study purposes only.